

MAPEO DETALLADO DE INDICADORES A REQUISITOS NORMATIVOS

Matriz de Alineación CIS Controls v8.1 ↔ NIST CSF 2.0 ↔ NIS2 ↔ GDPR ↔ ISO 27001 ↔ Regulaciones Españolas

Versión: 1.0

Fecha: Enero 2026

Propósito: Matriz exhaustiva mostrando qué requisito normativo específico cumple cada indicador/control

ESTRUCTURA DEL MAPEO

Cada fila contiene:

- **Indicador/Control CIS:** Nombre del control
- **CIS Safeguard:** Número específico de safeguard
- **NIST CSF 2.0:** Función y categoría alineada
- **NIS2 Directive:** Artículos relevantes
- **GDPR:** Artículos aplicables
- **ISO 27001:** Controles A.x.x mapeados
- **Regulaciones España:** INCIBE, CCN, ENS, LOPD-GDD
- **Criticidad:** CRÍTICO / ALTO / MEDIO

MÓDULO 1: GOBERNANZA, RIESGO Y CUMPLIMIENTO (GRC)

Control 1.1: Política de Ciberseguridad

Aspecto	Requisito Normativo	Artículo/Referencia	Obligatoriedad
CIS Safeguard	1.1 - Establish a comprehensive cybersecurity governance structure	CIS v8.1	Recomendado
NIST CSF 2.0	GV.PO (Policy, Processes, and Procedures)	NIST CSF 2.0 - GOVERN	Recomendado
NIS2 Directive	Artículo 17 - Obligation to ensure cybersecurity of networks and information systems	EU 2022/2555	OBLIGATORIO
	Artículo 21 - Supply chain risk management	EU 2022/2555	OBLIGATORIO
GDPR	Artículo 32 - Security of Processing (technical measures)	GDPR UE 2016/679	OBLIGATORIO
	Artículo 5 - Principles (integrity, confidentiality, availability)	GDPR UE 2016/679	OBLIGATORIO
ISO 27001	A.5.1 - Policies for information security	ISO/IEC 27001:2022	OBLIGATORIO (ISMS)
	A.5.2 - Information security roles and responsibilities	ISO/IEC 27001:2022	OBLIGATORIO
España - LOPD-GDD	Artículo 5 - Medidas técnicas y organizativas	LOPD-GDD Es 2018	OBLIGATORIO
España - ENS	Categoría III: Responsabilidades y gobernanza	ENS Español	OBLIGATORIO (crítica)
España - INCIBE	Marco de Indicadores de Ciberresiliencia	INCIBE 2024	Recomendado
España - CCN	Criterio 1: Gobierno y políticas	CCN/DCYBSI	OBLIGATORIO
Criticidad	CRÍTICO	Fundacional	⚠️

Observaciones:

- La política de ciberseguridad es **requisito base** para 100+ otros requisitos normativos
- NIS2 Art. 17 requiere "medidas técnicas y organizativas apropiadas"

- GDPR Art. 32 especifica que políticas deben documentarse y comunicarse
- ISO 27001 requiere aprobación de dirección de nivel superior
- España: ENS Categoría III requiere designación de CISO/responsable

Control 1.2: Comité de Governance de Seguridad

Aspecto	Requisito Normativo	Artículo/Referencia	Obligatoriedad
CIS Safeguard	1.2 - Establish and maintain a software inventory	CIS v8.1	Recomendado
NIST CSF 2.0	GV.OV (Oversight and Coordination)	NIST CSF 2.0 - GOVERN	Recomendado
NIS2 Directive	Artículo 20 - Risk assessment and management	EU 2022/2555	OBLIGATORIO
	Artículo 20(4) - Top management involvement	EU 2022/2555	OBLIGATORIO
GDPR	Artículo 33 - Notification to supervisory authority	GDPR UE 2016/679	OBLIGATORIO
ISO 27001	A.6.1 - Organizational activities	ISO/IEC 27001:2022	OBLIGATORIO
España - LOPD-GDD	Artículo 6 - Responsable y encargado del tratamiento	LOPD-GDD Es	OBLIGATORIO
España - ENS	Categoría III: Comité o figura equivalente	ENS Español	OBLIGATORIO (crítica)
Criticidad	CRÍTICO	Gobierno ejecutivo	⚠

MÓDULO 2: IDENTIFICACIÓN Y GESTIÓN DE ACTIVOS

Control 2.1: Inventario de Activos

Aspecto	Requisito Normativo	Artículo/Referencia	Obligatoriedad
CIS Safeguard	1.1 - Establish a comprehensive asset inventory	CIS v8.1	OBLIGATORIO IG1
NIST CSF 2.0	ID.AM (Asset Management)	NIST CSF 2.0 - IDENTIFY	Recomendado
NIS2 Directive	Artículo 20(3) - Asset and risk management	EU 2022/2555	OBLIGATORIO
GDPR	Artículo 32(1) - Maintain list of personal data processing	GDPR UE 2016/679	OBLIGATORIO
ISO 27001	A.8.1 - Asset responsibility	ISO/IEC 27001:2022	OBLIGATORIO
	A.8.3 - Acceptable use of assets	ISO/IEC 27001:2022	OBLIGATORIO
España - ENS	Categoría I: Inventario de activos información	ENS Español	OBLIGATORIO
Criticidad	CRÍTICO	Fundacional para todos controles	⚠

Observaciones:

- NIS2 requiere "inventario actualizado" de activos críticos
- GDPR exige registro de todos "tratamientos" de datos personales
- ISO 27001 A.8.1 requiere "owner" definido para cada activo
- España ENS Categoría I = mínimo obligatorio nacional

Control 2.2: Protección de Datos Personales

Aspecto	Requisito Normativo	Artículo/Referencia	Obligatoriedad
CIS Safeguard	3.1 - Configure systems to enforce data protection standards	CIS v8.1	OBLIGATORIO IG1
NIST CSF 2.0	PR.PS (Data Protection Processes)	NIST CSF 2.0 - PROTECT	Recomendado
NIS2 Directive	Artículo 20(1) - Confidentiality, integrity, availability	EU 2022/2555	OBLIGATORIO
GDPR	Artículo 5 - GDPR Principles (confidentiality)	GDPR UE 2016/679	OBLIGATORIO
	Artículo 32 - Technical and organizational measures	GDPR UE 2016/679	OBLIGATORIO
	Artículo 25 - Data Protection by Design and Default	GDPR UE 2016/679	OBLIGATORIO
LOPD-GDD	Artículo 5 - Medidas técnicas (encriptación, anonimización)	LOPD-GDD Es	OBLIGATORIO
ISO 27001	A.8.3 - Handling of information	ISO/IEC 27001:2022	OBLIGATORIO
	A.9.2 - User access management	ISO/IEC 27001:2022	OBLIGATORIO
Criticidad	CRÍTICO	Protección datos esenciales	⚠

Observaciones:

- GDPR Art. 32 especifica "encryption or pseudonymisation" donde sea posible
- NIS2 exige "encryption of data in transit and at rest"
- LOPD-GDD hereda GDPR pero añade requisitos españoles específicos
- Multas GDPR: hasta €20M o 4% facturación (lo que sea mayor)

MÓDULO 3: GESTIÓN DE IDENTIDAD Y ACCESO (IAM)

Control 3.1: Multifactor Authentication (MFA)

Aspecto	Requisito Normativo	Artículo/Referencia	Obligatoriedad
CIS Safeguard	6.4 - Require MFA for all user accounts on all systems	CIS v8.1	OBLIGATORIO IG2+
NIST CSF 2.0	PR.AA (Account and Access Management)	NIST CSF 2.0 - PROTECT	Recomendado
NIS2 Directive	Artículo 20(2) - Multi-factor authentication	EU 2022/2555	OBLIGATORIO crítica
GDPR	Artículo 32 - Appropriate technical measures	GDPR UE 2016/679	OBLIGATORIO
ISO 27001	A.9.2 - User authentication	ISO/IEC 27001:2022	OBLIGATORIO
España - ENS	Medida 2.1: Autenticación multifactor	ENS Español	OBLIGATORIO Cat. III
Criticidad	CRÍTICO	Breach prevention clave	⚠

Observaciones:

- NIS2 Art. 20(2) específicamente menciona "multi-factor authentication"
- CIS IG2 requiere MFA para "all administrative accounts"
- NIST CSF 2.0 recomienda MFA para "all user accounts"
- España ENS: obligatorio para acceso administrativo y datos sensibles

Control 3.2: Gestión de Acceso Privilegiado (PAM)

Aspecto	Requisito Normativo	Artículo/Referencia	Obligatoriedad
CIS Safeguard	5.1-5.4 - Account and Access Management	CIS v8.1	OBLIGATORIO IG2
NIST CSF 2.0	PR.AA (Privileged Access)	NIST CSF 2.0 - PROTECT	Recomendado
NIS2 Directive	Artículo 20 - Access restrictions (principle of least privilege)	EU 2022/2555	OBLIGATORIO
GDPR	Artículo 32 - Restriction of access	GDPR UE 2016/679	OBLIGATORIO
ISO 27001	A.9.1 - Access control policy	ISO/IEC 27001:2022	OBLIGATORIO
	A.9.2 - User registration and de-registration	ISO/IEC 27001:2022	OBLIGATORIO
Criticidad	CRÍTICO	Prevención de insider threats	⚠️

MÓDULO 4: PROTECCIÓN Y DETECCIÓN

Control 4.1: Vulnerability Management

Aspecto	Requisito Normativo	Artículo/Referencia	Obligatoriedad
CIS Safeguard	4.1 - Establish and maintain a detailed asset inventory	CIS v8.1	OBLIGATORIO IG1
NIST CSF 2.0	PR.PS (Asset Hardening)	NIST CSF 2.0 - PROTECT	Recomendado
NIS2 Directive	Artículo 20(3) - Vulnerability assessment and management	EU 2022/2555	OBLIGATORIO
GDPR	Artículo 32 - Regular testing of security measures	GDPR UE 2016/679	OBLIGATORIO
ISO 27001	A.12.6 - Vulnerability management	ISO/IEC 27001:2022	OBLIGATORIO
España - ENS	Medida 3.4: Evaluación de vulnerabilidades	ENS Español	OBLIGATORIO Cat. II/III
Criticidad	CRÍTICO	Prevención de exploits	⚠️

Observaciones:

- NIS2 exige "regular assessments" de vulnerabilidades

- GDPR Art. 32 requiere "regular testing" como parte de security measures
- ISO 27001 A.12.6 requiere "vulnerability management plan"
- España ENS requiere evaluación periódica según categoría (Cat. II: anual, Cat. III: semestral)

Control 4.4: Security Information and Event Management (SIEM)

Aspecto	Requisito Normativo	Artículo/Referencia	Obligatoriedad
CIS Safeguard	8.1-8.5 - Audit Log Management	CIS v8.1	OBLIGATORIO IG2
NIST CSF 2.0	DE.DP (Detection and Analysis)	NIST CSF 2.0 - DETECT	Recomendado
NIS2 Directive	Artículo 20(7) - Event logging and incident response	EU 2022/2555	OBLIGATORIO
GDPR	Artículo 32 - Ability to ensure ongoing integrity	GDPR UE 2016/679	OBLIGATORIO
	Artículo 33 - Timely notification (implies detection)	GDPR UE 2016/679	OBLIGATORIO
ISO 27001	A.8.4 - Information and other assets	ISO/IEC 27001:2022	OBLIGATORIO
	A.12.4 - Event logging	ISO/IEC 27001:2022	OBLIGATORIO
España - ENS	Medida 4.3: Monitoreo y logging	ENS Español	OBLIGATORIO Cat. II/III
Criticidad	CRÍTICO	Detección y respuesta	⚠️

Observaciones:

- NIS2 Art. 20(7) requiere "detection and prevention capabilities"
- GDPR Art. 32 especifica "testing" y "monitoring"
- ISO 27001 A.12.4 requiere "user activity logging"
- España ENS: logs deben retenerse mínimo 1 año (3 años para crítica)

Control 4.6: Respuesta a Incidentes

Aspecto	Requisito Normativo	Artículo/Referencia	Obligatoriedad
CIS Safeguard	17.1-17.2 - Incident Response	CIS v8.1	OBLIGATORIO IG2
NIST CSF 2.0	RS.MA (Response and Recovery)	NIST CSF 2.0 - RESPOND	Recomendado
NIS2 Directive	Artículo 23 - Incident handling and reporting	EU 2022/2555	OBLIGATORIO
	Artículo 23(4) - Report within 24 hours to national authority	EU 2022/2555	OBLIGATORIO
GDPR	Artículo 33 - Breach notification (72 hours)	GDPR UE 2016/679	OBLIGATORIO
	Artículo 34 - Notification to data subjects (if high risk)	GDPR UE 2016/679	OBLIGATORIO
ISO 27001	A.17.1 - Incident management	ISO/IEC 27001:2022	OBLIGATORIO
España - LOPD-GDD	Artículo 67 - Notificación de brechas (72h)	LOPD-GDD Es	OBLIGATORIO
España - ENS	Medida 5: Gestión de incidentes	ENS Español	OBLIGATORIO Cat. II/III
Criticidad	CRÍTICO	Compliance regulatorio	⚠

Observaciones:

- NIS2 exige reportar en 24h (más estricto que GDPR 72h)
- GDPR Art. 33 requiere "without undue delay and, in any case, not later than 72 hours"
- LOPD-GDD hereda el requisito 72h de GDPR
- ISO 27001 A.17.1 requiere documentación y prueba (drills) anual

MÓDULO 5: CONCIENCIA Y CAPACITACIÓN

Control 5.1: Programa de Conciencia de Seguridad

Aspecto	Requisito Normativo	Artículo/Referencia	Obligatoriedad
CIS Safeguard	14.1-14.3 - Security Training and Awareness	CIS v8.1	OBLIGATORIO IG1
NIST CSF 2.0	GV.RM (Risk Management) - Training	NIST CSF 2.0 - GOVERN	Recomendado
NIS2 Directive	Artículo 20(6) - Training of employees	EU 2022/2555	OBLIGATORIO
GDPR	Artículo 5(1)(f) - Integrity and confidentiality principle	GDPR UE 2016/679	OBLIGATORIO
	Artículo 32(2)(c) - Staff awareness and competence	GDPR UE 2016/679	OBLIGATORIO
ISO 27001	A.6.3 - Awareness, education and training	ISO/IEC 27001:2022	OBLIGATORIO
España - LOPD-GDD	Artículo 5(5) - Personal deber de cumplir normas	LOPD-GDD Es	OBLIGATORIO
España - ENS	Medida 1: Capacitación y conciencia	ENS Español	OBLIGATORIO Cat. I-III
Criticidad	ALTO	Riesgo humano crítico	⚠

Observaciones:

- NIS2 requiere "regular training" apropiada a roles
- GDPR Art. 32(2)(c) especifica "ensuring the competence of persons"
- ISO 27001 A.6.3 requiere programa formal documentado
- España ENS: capacitación mínima anual (revisión continua para Cat. III)

MÓDULO 6: CONTINUIDAD DE NEGOCIO Y RECUPERACIÓN

Control 6.1: Backup y Recuperación

Aspecto	Requisito Normativo	Artículo/Referencia	Obligatoriedad
CIS Safeguard	11.1-11.3 - Data Recovery	CIS v8.1	OBLIGATORIO IG2
NIST CSF 2.0	RC.CO (Coordination)	NIST CSF 2.0 - RECOVER	Recomendado
NIS2 Directive	Artículo 20(4) - Continuity measures	EU 2022/2555	OBLIGATORIO
GDPR	Artículo 32(1)(c) - Ensure availability and resilience	GDPR UE 2016/679	OBLIGATORIO
ISO 27001	A.12.3 - Backup	ISO/IEC 27001:2022	OBLIGATORIO
	A.17.2 - Business continuity	ISO/IEC 27001:2022	OBLIGATORIO
España - ENS	Medida 6: Respaldo y recuperación	ENS Español	OBLIGATORIO Cat. II/III
Criticidad	CRÍTICO	Availability assurance	⚠️

Observaciones:

- NIS2 Art. 20(4) requiere "regular backup"
- GDPR Art. 32(1)(c) especifica "resilience of systems" con backups
- ISO 27001 A.12.3 requiere "regular testing" de backups
- España ENS: RTO/RPO definido según criticidad (Cat. II: 72h RTO, Cat. III: 24h RTO)

MÓDULO 7: GESTIÓN DE RIESGOS CIBERNÉTICOS

Control 7.1: Riesgos Cuantificados

Aspecto	Requisito Normativo	Artículo/Referencia	Obligatoriedad
CIS Safeguard	1.3 - Enterprise asset inventory	CIS v8.1	Recomendado
NIST CSF 2.0	GV.RM (Risk Management)	NIST CSF 2.0 - GOVERN	Recomendado
NIS2 Directive	Artículo 20 - Risk assessment and management	EU 2022/2555	OBLIGATORIO
GDPR	Artículo 35 - Data Protection Impact Assessment (DPIA)	GDPR UE 2016/679	OBLIGATORIO (si necesario)
ISO 27001	A.12.6 - Vulnerability management	ISO/IEC 27001:2022	OBLIGATORIO
España - ENS	Medida 1: Evaluación de riesgos	ENS Español	OBLIGATORIO Cat. I-III
Criticidad	ALTO	Fundación de decisiones	⚠

MÓDULO 8: GESTIÓN DE RIESGO DE TERCEROS (SCRM)

Control 8.1: Evaluación de Proveedores

Aspecto	Requisito Normativo	Artículo/Referencia	Obligatoriedad
CIS Safeguard	15.1-15.3 - Service Provider Management	CIS v8.1	OBLIGATORIO IG2
NIST CSF 2.0	GV.SC (Supply Chain Risk Management)	NIST CSF 2.0 - GOVERN	Recomendado
NIS2 Directive	Artículo 21 - Supply chain risk management (NUEVO)	EU 2022/2555	OBLIGATORIO
GDPR	Artículo 28 - Processor agreements	GDPR UE 2016/679	OBLIGATORIO
	Artículo 32(4) - Processor obligations	GDPR UE 2016/679	OBLIGATORIO
ISO 27001	A.15.1 - Supplier relationships	ISO/IEC 27001:2022	OBLIGATORIO
España - ENS	Medida 7: Gestión de terceros	ENS Español	OBLIGATORIO Cat. II/III
Criticidad	CRÍTICO	Riesgo heredado crítico	⚠

Observaciones:

- NIS2 Art. 21 es NUEVO: requiere "risk assessment" de proveedores de servicios críticos
- GDPR Art. 28 requiere contratos con "Data Processing Agreements" (DPA)
- ISO 27001 A.15.1 requiere "supplier information security requirements"
- España ENS: auditorías de terceros críticos mínimo anual (Cat. III semestral)

Control 8.2: SBOM y Supply Chain Security

Aspecto	Requisito Normativo	Artículo/Referencia	Obligatoriedad
CIS Safeguard	1.1 - Asset inventory (includes software composition)	CIS v8.1	Recomendado
NIST CSF 2.0	GV.SC (Supply Chain Risk Management)	NIST CSF 2.0 - GOVERN	Recomendado
NIS2 Directive	Artículo 21 - Supplier management, including software	EU 2022/2555	OBLIGATORIO
GDPR	Artículo 32 - Technical measures (includes vendor software)	GDPR UE 2016/679	OBLIGATORIO
ISO 27001	A.14.2 - System development and support	ISO/IEC 27001:2022	OBLIGATORIO
Criticidad	ALTO	Supply chain visibility	⚠

Observaciones:

- NIS2 exige evaluación de "software and components" de proveedores
- CISA (US) ahora requiere SBOM para federal contracts
- Europa está moviendo en dirección similar (EU Cyber Resilience Act en borrador)
- ISO 27001 A.14.2 requiere "source code review" cuando sea posible

RESUMEN DE CRITICIDAD POR NORMATIVA

Regulación	Indicadores Críticos	Score PRAGMATIC Promedio
NIS2	Política, MFA, SIEM, Respuesta Incidentes, SCRM	2.73 (ALTO)
GDPR	Política, Protección Datos, Encriptación, DPIA	2.67 (ALTO)
ISO 27001	8 Controles A.x.x fundamentales	2.56 (ALTO)
España ENS	Categoría I: 5 mínimos; Cat. III: +15 adicionales	Variable
INCIBE	Alineado a NIST/NIS2; recomendaciones	2.55 (PROMEDIO)

NOTAS CRÍTICAS

Para Entidades NIS2-Afectadas (España)

- 4.000 empresas grandes + 1.819 operadores esenciales bajo NIS2
- Plazo transposición España: Octubre 2024 (Real Decreto en elaboración)
- Multas NIS2: Hasta €10M o 2% facturación global (lo que sea mayor)
- Reporte incidentes: 24 horas a autoridad nacional

Para Todas las Organizaciones (GDPR)

- Multas GDPR: Hasta €20M o 4% facturación (lo que sea mayor)
- DPIA obligatoria si: datos sensibles, procesamiento a escala, o evaluación sistemática
- DPA requerida con cualquier proveedor que procese datos personales

Para Entidades Críticas (España)

- ENS Categoría III: Obligatorio para infraestructura crítica (energía, agua, finanzas, salud, telecomunicaciones)
- Auditorías: Mínimo semestral para Category III
- CISO Dedicado: Obligatorio para operadores esenciales

Documento Versión 1.0 | Enero 2026 | España